

THRESHOLD ENTERPRISE SYSTEMS

Information Security Policy

Document Id	SEC-001
Title	Information Security Policy
Department	Information Security
Classification	INTERNAL
Version	2.0
Status	ACTIVE
Effective Date	2026-01-15
Document Type	POLICY
Allowed Roles	EMPLOYEE, MANAGER, ENGINEER, AI_ENGINEER, SECURITY_ENGINEER, OPERATIONS_MANAGER, HR_MANAGER, ADMIN

1. Purpose, Organizational Scope, and Strategic Objectives

Threshold Enterprise Systems operates as a multinational provider of enterprise artificial intelligence platforms, cloud computing infrastructure, big data solutions, and digital transformation services. Operating across India, the United States, the United Kingdom, and Singapore with approximately 5,000 employees, our organization handles sensitive corporate, client, and algorithmic assets. Preserving trust, operational availability, and data sovereignty requires an uncompromising commitment to information security.

The purpose of this Information Security Policy is to define the foundational principles, operational governance, management expectations, and individual responsibilities necessary to safeguard corporate digital and physical assets against unauthorized access, compromise, disruption, modification, or destruction. This policy serves as the apex document in the Threshold Enterprise Systems information security policy hierarchy.

This policy applies universally to all business units, operating subsidiaries, engineering environments, corporate networks, computing hardware, cloud tenants, and data repositories owned or leased by Threshold Enterprise Systems. It governs all workforce members, including full-time employees, part-time personnel, contractors, interns, and authorized third-party vendors accessing enterprise systems.

2. Core Information Security Principles (CIA Triad and Non-Repudiation)

Information security governance at Threshold Enterprise Systems is architected around four core foundational principles:

- Confidentiality:** Protecting information assets from unauthorized disclosure, observation, or interception. Access to sensitive data is governed by the principle of least privilege, strict need-to-know controls, and role-based access configurations.
- Integrity:** Ensuring the accuracy, completeness, authenticity, and reliability of information assets and processing algorithms. Digital assets must be safeguarded against unauthorized or accidental modification, tampering, or deletion through cryptographic controls, audit logs, and checksum validation.
- Availability:** Ensuring authorized users have reliable, timely, and uninterrupted access to critical computing resources, application services, and business datasets. Resilience is engineered through high-availability infrastructure, automated failover, distributed geographic backups, and proactive disaster recovery planning.
- Non-Repudiation:** Guaranteeing that digital actions, transactional authorizations, administrative system changes, and access events can be definitively attributed to an authenticated identity through immutable cryptographic logging and centralized audit trails.

3. Three Lines of Defense Governance Model

To maintain rigorous operational oversight and eliminate single points of failure, Threshold Enterprise Systems implements the Three Lines of Defense governance model:

First Line of Defense (Operational Management and Engineering): Business units, software engineering squads, AI development teams, and IT operations personnel who design, build, deploy, and maintain systems. First-line personnel are directly responsible for implementing security controls, conducting code reviews, remediating vulnerabilities, and maintaining day-to-day security hygiene.

Second Line of Defense (Information Security and Enterprise Risk Management): The Information Security department, led by the Chief Information Security Officer (CISO), establishes enterprise security architectures, monitors risk posture, defines security standards, conducts penetration testing, and oversees compliance with industry frameworks including ISO/IEC 27001, SOC 2 Type II, and NIST Cybersecurity Framework.

Third Line of Defense (Internal Audit and Enterprise Governance): Independent internal and external auditors who evaluate the efficacy of first- and second-line controls, reporting directly to the Board Audit and Governance Committee.

4. Employee Information Security Responsibilities

Every workforce member shares personal accountability for safeguarding enterprise information assets. Core responsibilities include:

- **Workstation Security:** Locking device screens whenever stepping away from workstations (using Windows Key + L or Cmd + Ctrl + Q), maintaining automated screen timeouts of five minutes or less, and ensuring confidential data is shielded from unauthorized visual observation (shoulder surfing).
- **Clean Desk and Clean Screen Standards:** Removing sensitive printed documents, access badges, and storage media from desks when unattended. Shredding sensitive physical materials immediately following use.
- **Credential Stewardship:** Protecting individual login credentials, using approved multi-factor authentication (MFA) devices, and never sharing account credentials with colleagues, managers, or external entities.
- **Software and Device Integrity:** Using exclusively company-provided endpoint hardware enrolled in enterprise mobile device management (MDM) with active endpoint detection and response (EDR) software. Refraining from installing unapproved third-party software.
- **Vigilance Against Social Engineering:** Exercising caution when evaluating emails, instant messages, and phone calls. Reporting suspicious communications, unexpected credential verification prompts, and urgent financial or configuration requests to security operations immediately.

5. Management Responsibilities and Tone from the Top

People Managers, Technical Team Leads, and Executive Directors bear heightened responsibility for instilling a security-first culture within their respective teams.

Managers must ensure that all direct reports complete mandatory annual security awareness training within designated corporate deadlines. When onboarding new team members, managers must ensure access requests adhere strictly to least-privilege principles, granting access only to systems essential for active project execution.

During project planning and sprint grooming, technical leaders must allocate sufficient engineering capacity to address technical debt, dependency vulnerabilities, and security architecture recommendations. Managers must never pressure team members to bypass security controls, skip code reviews, or deploy untested software to meet commercial delivery targets.

6. Security Awareness, Training, and Phishing Resilience

Human error remains a primary vector in cyber intrusions. To foster continuous vigilance, Threshold Enterprise Systems requires all personnel to participate in our continuous Security Awareness Program.

New hires must complete foundational information security training during their initial two-week onboarding period prior to receiving access to production systems or confidential data repositories. All active personnel must complete annual recertification training covering emerging threat vectors, social engineering tactics, credential security, and data privacy.

The Information Security department conducts periodic, unannounced simulated phishing exercises to test workforce resilience. Employees who identify and report simulated attacks via the 'Report Phishing' client button receive positive recognition. Employees who interact with simulated malicious links or disclose credentials are automatically enrolled in targeted, constructive remedial training modules.

7. Protection of Enterprise Information and Computing Assets

All enterprise computing assets—including cloud-hosted services, on-premises servers, developer workstations, proprietary software algorithms, client data, and network infrastructure—must be managed throughout their lifecycle in accordance with enterprise security baselines.

Data Classification: All information created, processed, or stored across enterprise systems must be categorized in accordance with our four-tier classification model: PUBLIC, INTERNAL, CONFIDENTIAL, or RESTRICTED, as defined in SEC-005. Handling procedures, encryption controls, and access restrictions must correspond to the assigned classification.

Cryptographic Protection: Sensitive data must be encrypted both in transit (using modern protocols such as TLS 1.3) and at rest (using AES-256 encryption). Cryptographic keys must be managed through dedicated hardware security modules (HSMs) or enterprise key management services with dual-authorization separation.

Network Security: Enterprise networks are protected by next-generation firewalls, intrusion detection/prevention systems (IDS/IPS), and zero-trust software-defined perimeters. Direct, unfiltered ingress from the public internet into corporate compute environments is strictly prohibited.

8. Incident Reporting Overview and Scope Distinction

Prompt reporting of suspected security events is critical for rapid threat containment, forensic analysis, and damage mitigation. All personnel are required to report any observed or suspected security anomalies immediately to the 24/7 Information Security Operations Center (ISOC).

Examples of reportable security incidents include: malware alerts, suspected account takeover, unauthorized access attempts, lost or stolen laptops, accidental data leakage, ransomware extortion notices, or suspicious multi-factor authentication approval prompts.

CRITICAL SCOPE DISTINCTION: Employees must carefully distinguish Cybersecurity Incidents from Physical Workplace Incidents. Cybersecurity incidents involve digital assets, network intrusions, data breaches, or credential compromise, and must be reported to the ISOC under the Security Incident Response Policy (SEC-004). In contrast, physical slips/falls, facility safety hazards, workplace harassment, or interpersonal disputes represent Workplace Incidents governed separately by Human Resources under HR-008.

9. Compliance Auditing, Monitoring, and Telemetry

Threshold Enterprise Systems reserves the right to monitor, audit, inspect, and log all communications, file transfers, command executions, and access events occurring on or traversing corporate networks, computing endpoints, and cloud tenants, in full compliance with applicable regional privacy regulations.

Automated endpoint telemetry and Security Information and Event Management (SIEM) systems continuously analyze system logs to detect anomalous behaviors, privilege escalation, unauthorized lateral movement, and data exfiltration indicators.

Periodic independent compliance audits are conducted by accredited third-party auditing firms to validate organizational conformity with ISO/IEC 27001 standards, SOC 2 Trust Services Criteria, and customer contractual security commitments.

10. Policy Compliance, Violations, and Disciplinary Sanctions

Adherence to this Information Security Policy is mandatory for all workforce members. Compliance is assessed through automated posture checks, internal audit assessments, and supervisory reviews.

Violations of this policy compromise the safety of our enterprise infrastructure and client data. Breaches are investigated impartially by Information Security in coordination with Employee Relations and Legal.

Depending on severity, intentionality, and potential business impact, violations may result in corrective actions ranging from formal written reprimands and mandatory retraining to immediate revocation of system privileges, suspension, and termination of employment for cause. In cases involving intentional data theft, intellectual property espionage, or sabotage, the company may initiate civil litigation and refer cases to regional law enforcement agencies.

11. Integration with Specialized Information Security Policies

This policy establishes high-level enterprise security expectations and operates in direct conjunction with specialized, topic-specific security policies:

- SEC-002: Access Control Policy (Role-based access, least privilege, and approval workflows).
- SEC-003: Password and Authentication Policy (Credential standards, MFA mandates, and account recovery).
- SEC-004: Security Incident Response Policy (Technical incident handling, triage, containment, and forensics).
- SEC-005: Data Classification and Handling Policy (Classification tiers, labeling, retention, and cryptographic disposal).
- SEC-006: Acceptable Use Policy (Rules governing device, internet, communication, and software usage).
- SEC-007: Production Access Policy (Restricted zero-trust controls for live production cloud environments).

12. Policy Review, Ownership, and Administration

This Information Security Policy is owned by the Chief Information Security Officer (CISO) and administered by the Information Security department. It is formally reviewed annually by the Information Security Steering Committee and ratified by the Enterprise Governance Board.

Substantive amendments reflecting significant technological shifts, emerging threats, or regulatory changes are communicated to all employees via corporate announcement channels and published immediately in the enterprise knowledge base.

Inquiries regarding the interpretation or practical application of this policy should be directed to the Information Security Governance, Risk, and Compliance (GRC) team at infosec-grc@threshold-systems.internal.